

SECURITY OPERATIONS CENTER

INCIDENT RESPONSE REPORT

RDP Brute-Force Compromise – WINDOWS-VICTIM

Incident ID	INC-2026-001
Classification	TLP:AMBER – Restricted Distribution
Severity	Critical
Incident Date	10 July 2026
Report Prepared By	Afzal M — SOC Analyst (Detection Engineering)
Report Date	11 July 2026

Table of Contents

1. Executive Summary.....	1
2. Incident Classification.....	1
3. Scope and Environment.....	1
4. Identification.....	1
4.1 Initial Access — Brute Force Authentication.....	1
4.2 Execution — Interactive Session Establishment.....	1
4.3 Persistence — Unauthorized Account Creation.....	1
4.4 Discovery — System and Account Enumeration.....	1
4.5 Defense Evasion — Attempted Log Clearing.....	1
4.6 Impact — Attempted Local Data Access.....	1
5. Timeline.....	1
6. Containment.....	1
7. Eradication.....	1
8. Recovery.....	1
9. Lessons Learned.....	1
10. Appendix A — Indicators of Compromise.....	1
11. Appendix B — Detection Rules.....	1
12. Appendix C — References.....	1

1. Executive Summary

On 10 July 2026, repeated authentication failures were detected against the RDP service on host WINDOWS-VICTIM (192.168.56.106). Correlation logic identified the pattern as a brute-force attack (MITRE ATT&CK T1110.001), and a successful authentication using the account **afzal_vic** shortly after the failed attempts escalated the event to Critical severity (Wazuh Rule 100011, Level 15).

Following access, the attacker established an interactive session, created an unauthorized local administrator account (bobthebad), performed local system and account reconnaissance, and attempted to clear the Windows Security event log to remove evidence of activity. The attempted log-clearing action was itself captured and attributed to the compromised account. The incident was contained by disabling the unauthorized account and blocking the source of the attack traffic. No evidence of lateral movement to other hosts was identified.

Key Findings

- **Credential Vulnerability:** The compromised account was accessible using a weak, dictionary-guessable password, allowing credential compromise via brute force in under two minutes.
- **Immediate Persistence:** The attacker escalated privileges immediately upon access by creating a new local administrator account.
- **Defensive Evasion Visibility:** An attempt to clear the Security event log was detected and directly attributed to the compromised account's session, demonstrating that defense-evasion actions can themselves generate high-value detection evidence.
- **Visibility Gaps:** Discovery activity (net user) was captured by existing detection rules; broader discovery commands (whoami, systeminfo) were not captured due to a Sysmon configuration gap identified during investigation (see Section 9).
- **Limited Impact:** No evidence of lateral movement or data exfiltration to systems outside the affected host was identified.

2. Incident Classification

Attribute	Assessment
Incident Type	Unauthorized Access / Account Compromise
Attack Vector	Remote Desktop Protocol (RDP), Network Level Authentication not enforced
Confidentiality Impact	Medium
Integrity Impact	High
Availability Impact	Low
Overall Severity	Critical

3. Scope and Environment

Host / IP	Role	Monitoring
192.168.56.107	Source of attack traffic	N/A
WINDOWS-VICTIM (192.168.56.106)	Target endpoint — Windows 10	Wazuh agent, Sysmon
UBUNTU-SIEM (192.168.56.104)	Wazuh manager / indexer	Self-monitored

4. Identification

Detection Summary

Phase	MITRE ATT&CK	Detection Source
Initial Access	T1110.001	Wazuh Rule 100010 / 100011
Execution	T1078	Wazuh Rule 92653 (Logon Type 10)
Persistence	T1136.001	Windows Event 4720 / Wazuh Rule 60109
Discovery	T1087	Wazuh Rule 92031 (net.exe)
Defense Evasion	T1070.001	Windows Event 1102 / Wazuh Rule 63103
Impact	T1005	Not captured — monitoring gap, see Section 9

4.1 Initial Access — Brute Force Authentication

MITRE ATT&CK: T1110.001

A sustained series of RDP authentication failures against account afzal_vic was detected from the attack source. The pattern met the threshold defined in custom correlation Rule 100010 (5 failures within 120 seconds), escalating to Level 12. A successful authentication from the same source followed shortly after, triggering Rule 100011 (Level 15, Critical), which correlates brute-force activity with a subsequent successful logon. The compromised password was present in a common password wordlist, indicating insufficient password complexity for a privileged, network-exposed account.

Jul 10, 2026 @ 09:59:54.581	001	Windows-Victim	T1110 T1078	Credential Access, Defense Evasion, Persistence, Privilege Escalation, Initial Access	CRITICAL: Successful login after brute force attack - possible account compromise.	15	100011
Table	JSON	Rule					
@timestamp		2026-07-10T04:29:54.581Z					
_id		09xKSp8Bwxa1x6PUF12o					
agent.id		001					
agent.ip		192.168.56.106					
agent.name		Windows-Victim					
data.win.eventdata.authenticationPackageName		NTLM					
data.win.eventdata.failureReason		%%2313					
data.win.eventdata.ipAddress		192.168.56.1					
data.win.eventdata.ipPort		0					
data.win.eventdata.keyLength		0					
data.win.eventdata.logonProcessName		NtLmSsp					
data.win.eventdata.logonType		3					
data.win.eventdata.processId		0x0					

4.2 Execution — Interactive Session Establishment

MITRE ATT&CK: T1078

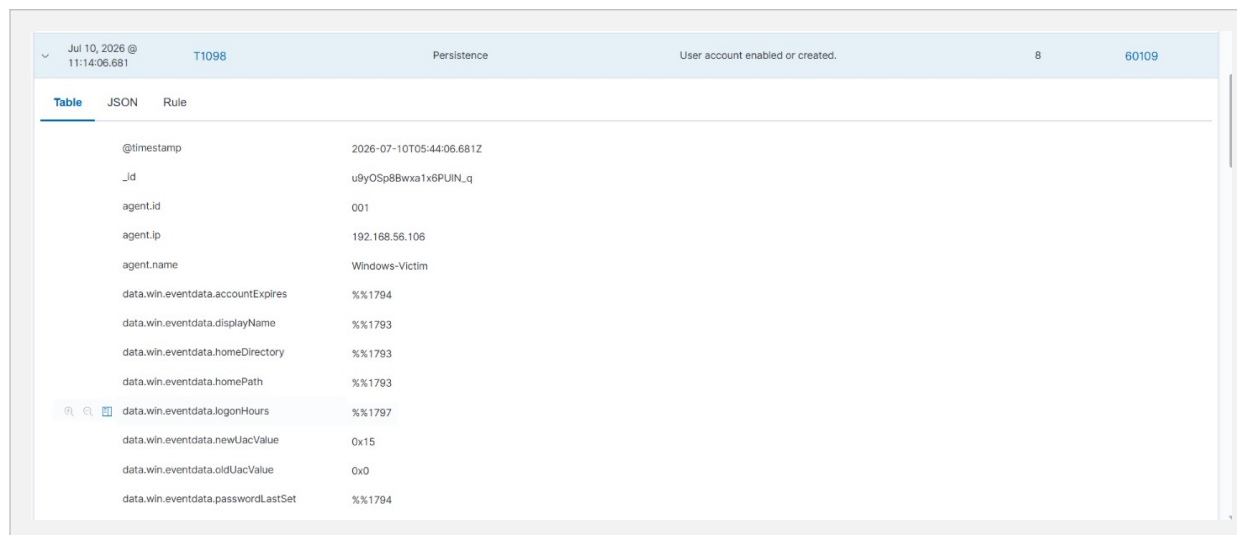
Following credential compromise, an interactive RDP session was established using the afzal_vic account, recorded as Logon Type 10 (RemoteInteractive) under Wazuh Rule 92653. This is distinct from the network-logon (Type 3) authentication event captured during the initial brute-force phase, confirming a genuine interactive session was opened rather than a credential-validation attempt alone. Note: the source IP recorded for this session (192.168.56.1) reflects the host-only network gateway address rather than the originating host's direct address, a known artifact of the virtualized network configuration used in this environment.

Jul 10, 2026 @ 10:14:08.106	001	Windows-Victim	T1021.001 T1078.002	Local or Remote Administration, Defense Evasion, Persistence, Privilege Escalation, Initial Access	User: WORKGROUP\afzal_vic logged using Remote Desktop Connection (RDP) from ip:192.168.56.1.	3	92653
Table	JSON	Rule					
@timestamp		2026-07-10T04:44:08.106Z					
_id		N9xXSp8Bwxa1x6PUKNSB					
agent.id		001					
agent.ip		192.168.56.106					
agent.name		Windows-Victim					
data.win.eventdata.authenticationPackageName		Negotiate					
data.win.eventdata.elevatedToken		%%1842					
data.win.eventdata.impersonationLevel		%%1833					
data.win.eventdata.ipAddress		192.168.56.1					
data.win.eventdata.ipPort		0					
data.win.eventdata.keyLength		0					
data.win.eventdata.logonGuid		{00000000-0000-0000-0000-000000000000}					
data.win.eventdata.logonProcessName		User32					
data.win.eventdata.logonType		10					

4.3 Persistence — Unauthorized Account Creation

MITRE ATT&CK: T1136.001

Within the interactive session, a new local account (bobthebad) was created and added to the local Administrators group. This activity was captured under Windows Security Event ID 4720 and correlated by Wazuh Rule 60109 (Level 8, "User account enabled or created"). The immediate creation of a privileged account following initial access is a strong indicator of an intent to establish persistent, privileged access independent of the original compromised credential.



The screenshot displays the Wazuh console interface for a specific event. At the top, a header bar contains the following information: a dropdown menu showing 'Jul 10, 2026 @ 11:14:06.681', the event ID 'T1098', the category 'Persistence', the rule name 'User account enabled or created.', the level '8', and the rule ID '60109'. Below this header, a table with the title 'Table' is shown. The table has two columns: 'JSON' and 'Rule'. The 'JSON' column lists various event data fields, and the 'Rule' column shows the corresponding rule ID for each field. The fields listed are: '@timestamp' (2026-07-10T05:44:06.681Z), '_id' (u9yOSp8Bwxa1x6PUIN_q), 'agent.id' (001), 'agent.ip' (192.168.56.106), 'agent.name' (Windows-Victim), 'data.win.eventdata.accountExpires' (%1794), 'data.win.eventdata.displayName' (%1793), 'data.win.eventdata.homeDirectory' (%1793), 'data.win.eventdata.homePath' (%1793), 'data.win.eventdata.logonHours' (%1797), 'data.win.eventdata.newUacValue' (0x15), 'data.win.eventdata.oldUacValue' (0x0), and 'data.win.eventdata.passwordLastSet' (%1794).

JSON	Rule
@timestamp	2026-07-10T05:44:06.681Z
_id	u9yOSp8Bwxa1x6PUIN_q
agent.id	001
agent.ip	192.168.56.106
agent.name	Windows-Victim
data.win.eventdata.accountExpires	%1794
data.win.eventdata.displayName	%1793
data.win.eventdata.homeDirectory	%1793
data.win.eventdata.homePath	%1793
data.win.eventdata.logonHours	%1797
data.win.eventdata.newUacValue	0x15
data.win.eventdata.oldUacValue	0x0
data.win.eventdata.passwordLastSet	%1794

4.4 Discovery — System and Account Enumeration

MITRE ATT&CK: T1087

Discovery commands were executed within the session, including net user for local account enumeration. This activity was captured by existing Wazuh Rule 92031 ("Discovery activity executed", Level 3). A custom correlation rule (100031) intended to capture a broader set of discovery utilities (whoami, systeminfo, ipconfig) did not fire during testing; subsequent investigation attributed this to a Sysmon configuration exclusion rather than a Wazuh rule logic error, as detailed in Section 9.

	Jul 10, 2026 @ 16:09:55.432	T1087	Discovery	Discovery activity executed	3	92031
Table	JSON	Rule				
@timestamp	2026-07-10T10:39:55.432Z					
_id	ZWqcS58BNLgre4O3SVtY					
agent.id	001					
agent.ip	192.168.56.106					
agent.name	Windows-Victim					
data.win.eventdata.commandLine	net user					
data.win.eventdata.company	Microsoft Corporation					
data.win.eventdata.currentDirectory	C:\Windows\system32\					
data.win.eventdata.description	Net Command					
data.win.eventdata.fileVersion	10.0.19041.1 (WinBuild.160101.0800)					
data.win.eventdata.hashes	MD5=0BD94A338EEA5A4E1F2830AE326E6D19,SHA256=9F376759BCBCD705F726460FC4A7E2B07F310F52BAA73CAAAA124FDD8DF993E,IMPHASH=57F0C47AE2A1A2C06C8B987372AB0B07					
data.win.eventdata.image	C:\Windows\System32\net.exe					
data.win.eventdata.integrityLevel	High					
data.win.eventdata.logonGuid	{f051d258-c90f-6a50-bc5b-090000000000}					

4.5 Defense Evasion — Attempted Log Clearing

MITRE ATT&CK: T1070.001

An attempt was made to clear the Windows Security event log (wevtutil cl Security). This action was captured under Windows Security Event ID 1102 and correlated by Wazuh Rule 63103 (Level 5, "The audit log was cleared"). Critically, the event explicitly attributed the action to the compromised account (afzal_vic), directly linking the defense-evasion attempt to the same identity used throughout the incident. This illustrates that anti-forensic actions frequently generate their own high-value detection evidence.

	Jul 10, 2026 @ 16:17:48.019	T1070	Defense Evasion	The audit log was cleared	5	63103
Table	JSON	Rule				
@timestamp	2026-07-10T10:47:48.019Z					
_id	bmQKS58BNLgre4O3Mftf					
agent.id	001					
agent.ip	192.168.56.106					
agent.name	Windows-Victim					
data.win.logFileCleared.clientProcessId	7004					
data.win.logFileCleared.clientProcessStartKey	14355223812243818					
data.win.logFileCleared.subjectDomainName	DESKTOP-M9R4BC0					
data.win.logFileCleared.subjectLogonId	0x95bbc					
data.win.logFileCleared.subjectUserName	afzal_vic					
data.win.logFileCleared.subjectUserSid	S-1-5-21-2360609687-1737134593-1637317434-1001					
data.win.system.channel	Security					
data.win.system.computer	DESKTOP-M9R4BC0					
data.win.system.eventID	1102					
data.win.system.eventRecordID	7939					

4.6 Impact — Attempted Local Data Access

MITRE ATT&CK: T1005

An attempt to access and copy a file from the user's local profile was performed within the session. This action did not generate a corresponding Sysmon or Wazuh alert. Investigation determined this was a monitoring gap rather than an absence of activity; see Section 9 for root cause and remediation recommendations.

5. Timeline

Time (UTC)	Event	Source
09:59:54	Brute-force threshold met; successful authentication correlated	Wazuh Rule 100011
10:14:08	Interactive RDP session established (Logon Type 10)	Wazuh Rule 92653
10:39:55	Discovery command (net user) executed	Wazuh Rule 92031
10:47:48	Security event log clear attempted	Wazuh Rule 63103
11:14:06	Unauthorized local administrator account created	Wazuh Rule 60109 / Event 4720

Note: Event ordering reflects the sequence in which activity was performed and captured during testing. In a live intrusion, persistence is typically established earlier in the chain; the ordering above is specific to this exercise.

6. Containment

- Disabled the unauthorized account (bobthebad) to prevent further use.
- Applied a host-based firewall rule blocking the source of the attack traffic.
- Preserved Wazuh alert data and Sysmon telemetry prior to remediation.

7. Eradication

- Removed the unauthorized local administrator account.
- Reset credentials for the compromised account (afzal_vic) to a value meeting complexity requirements.
- Verified no additional persistence mechanisms (scheduled tasks, registry run keys) were present.

8. Recovery

- Confirmed Wazuh agent and Sysmon services healthy and reporting.
- Verified file integrity via syscheck baseline comparison.

- Returned host to normal operational status.

9. Lessons Learned

Detection Gaps Remediated

Gap	Remediation
No correlation existed for repeated RDP authentication failures	Authored Rule 100010 — 5 failures within 120 seconds escalate to Level 12
No correlation existed between brute-force activity and subsequent successful logon	Authored Rule 100011 — chains Rule 100010 to a successful-logon event, escalating to Level 15 (Critical)
Individual discovery commands did not alert; naive per-command alerting risks alert fatigue	Authored frequency-based Rule 100031 to correlate multiple discovery commands into a single alert

Detection Gaps Identified — Not Yet Remediated

Gap	Assessment
Rule 100031 did not fire for whoami, systeminfo, or ipconfig during live testing	Root cause traced to the Sysmon configuration baseline (SwiftOnSecurity), which excludes several common built-in utilities from logging to reduce volume. These events did not reach Wazuh regardless of rule logic. Remediation: adjust the Sysmon configuration to include these binaries, or accept the exclusion as an intentional noise-reduction tradeoff and rely on complementary detections (e.g., command-line auditing via Event ID 4688).
File access/copy activity during the Impact phase did not generate a Sysmon or Wazuh alert	Likely attributable to the same Sysmon exclusion behavior affecting FileCreate events for the target path/extension. Remediation: review and tighten Sysmon FileCreate filtering for user-profile and Temp directories.

False Positives Tuned

Finding	Resolution
Rule 92213 flagged PowerShell's internal script-policy self-test file as a malicious dropped executable	Authored suppression Rule 100030 (Level 0) matching the specific benign filename pattern
Rule 92217 flagged Windows Defender's routine signature update as a suspicious file drop	Documented; recommend tuning by parent-process and file-path validation

Root Cause

RDP was reachable without account lockout policy or Network Level Authentication (NLA) enforced, and the compromised account's password lacked sufficient complexity, allowing a brute-force attack to succeed against a valid account within a short time window.

Recommendations

- Restrict direct RDP exposure; require VPN or bastion host access for remote administration.
- Enforce account lockout policy (e.g., 5 attempts / 15-minute lockout) and minimum password complexity.
- Enable Network Level Authentication (NLA) on all RDP services.
- Review and adjust the Sysmon configuration baseline to close the discovery- and file-access-logging gaps identified in this incident.
- Periodically tune high-noise Sysmon rules using process path and parent-process validation to reduce false positive rate.

10. Appendix A — Indicators of Compromise

Type	Value	Description
Source	192.168.56.107	Origin of attack traffic (recorded as 192.168.56.1 in Windows event data due to host-only NAT gateway artifact)
Target IP	192.168.56.106	Affected host (WINDOWS-VICTIM)
Compromised Account	afzal_vic	Account accessed via brute force; password met a common dictionary wordlist
Unauthorized Account	bobthebad	Created for persistence, added to local Administrators group
Attack Tooling	THC-Hydra, FreeRDP (xfreerdp)	Tools used to conduct credential brute-force and establish remote access

11. Appendix B — Detection Rules

Custom Wazuh correlation and suppression rules authored as part of this investigation (local_rules.xml):

- Rule 100010 — Level 12 — Brute-force correlation (5 failures / 120s, if_matched_sid 60122)
- Rule 100011 — Level 15 — Success-after-brute-force correlation (if_matched_sid 100010, if_sid 60106)
- Rule 100030 — Level 0 — False-positive suppression for PowerShell script-policy self-test file
- Rule 100031 — Level 8 — Discovery command correlation (2 events / 180s, if_matched_group sysmon_event1)

Full rule definitions are maintained in the accompanying local_rules.xml file in this repository.

12. Appendix C — References

- MITRE ATT&CK Framework — attack.mitre.org
- SANS Incident Handler's Handbook (PICERL) — sans.org/white-papers/33901

- NIST SP 800-61 Rev. 2 — Computer Security Incident Handling Guide